

DISEÑO DE ARQUITECTURA DE BANCA DIGITAL BP

Arquitecto de Soluciones: Milton Quintana

Resumen ejecutivo

La recomendación es construir la capa de banca digital sobre AWS y mantener el Core Bancario, el sistema de detalle de cliente y el entorno de pagos/interbancario como sistemas corporativos de registro. La nube se utilizaría para los canales digitales, seguridad de borde, APIs, servicios de aplicación, mensajería, caché, auditoría y observabilidad. Esta separación reduce el acoplamiento con los legados y permite evolucionar web y móvil sin exponer el Core directamente a Internet.

El diseño conserva las tres capacidades principales planteadas en el ejercicio -consulta de cliente, consulta de movimientos y transacciones- y añade únicamente servicios de soporte que tienen una responsabilidad claramente distinta: onboarding/KYC, notificaciones y auditoría. Se evita fragmentar el backend en microservicios innecesarios.

Ámbito	Decisión propuesta
Canales	SPA React + TypeScript y aplicación móvil Flutter. React Native se mantiene como alternativa si BP ya dispone de una práctica consolidada en React/TypeScript.
Identidad	OAuth 2.0 / OpenID Connect. Web con Backend for Frontend (BFF); móvil con Authorization Code + PKCE y user-agent externo. MFA/step-up para operaciones sensibles.
Onboarding	Prueba de identidad con documento, liveness y comparación facial. La biometría de onboarding se trata como identity proofing; no se confunde con la autorización OAuth.
Integración	API Gateway y adaptadores/Anti-Corruption Layer para aislar al dominio de contratos, formatos y protocolos del Core, del sistema de detalle y del hub de pagos.
Asincronía	Amazon EventBridge + SQS + DLQ para notificaciones, auditoría derivada y otros efectos secundarios. Kafka/MSK se reserva para un escenario futuro que realmente requiera streaming, replay o alto throughput.
Resiliencia	Timeouts, retry selectivo, circuit breaker, bulkheads, idempotency key, Transactional Outbox y reconciliación de estados desconocidos.
Disponibilidad	Multi-AZ en la región primaria y warm standby en una segunda región. La región se mantiene como decisión condicionada a latencia, disponibilidad de servicios y cumplimiento.
Ecuador	LOPDP y normativa SPDP vigente; Codificación vigente de la Superintendencia de Bancos sobre riesgo operativo, terceros y cloud; y reglas operativas del Banco Central para pagos interbancarios.

Contenido

- 1. Enfoque metodológico de diseño
- 2. Alcance, requisitos y supuestos
- 3. Drivers arquitectónicos y criterios de calidad
- 4. Arquitectura recomendada y decisiones maestras
- 5. C4 Nivel 1 - Contexto
- 6. C4 Nivel 2 - Contenedores

Nota de lectura: el Nivel 2 se divide en cuatro vistas para mantener cada gráfico legible: 2A canales y acceso, 2B servicios de aplicación, 2C datos y mensajería y 2D integraciones externas/ACL.

- 7. C4 Nivel 3 - Componentes
- 8. Flujos críticos

Los diagramas de secuencia complementan C4 y muestran el orden temporal de la autenticación y las transacciones; no constituyen un nivel adicional del modelo C4.

- 9. Datos, caché y auditoría
- 10. Resiliencia y consistencia
- 11. Despliegue AWS, Well-Architected, alta disponibilidad y DR
- 12. Seguridad y observabilidad
- 13. Marco regulatorio ecuatoriano
- 14. Decisiones arquitectónicas y alternativas
- 15. Costos, operación y riesgos abiertos
- 16. Trazabilidad contra el ejercicio
- 17. Referencias

1. Enfoque metodológico de diseño

El diseño sigue un proceso trazable en el que las decisiones técnicas se derivan del contexto del banco, de los requisitos del ejercicio y de los atributos de calidad que condicionan la solución. Para este propósito se utiliza Attribute-Driven Design (ADD 3.0) como guía de diseño, el modelo C4 para comunicar las vistas arquitectónicas, registros ADR para documentar decisiones y AWS Well-Architected como referencia de evaluación de la carga en nube.

Contexto y requisitos → ASR y drivers → Patrones / tácticas → Decisiones → Tecnologías → C4 / ADR → Evaluación e iteración

La tecnología se selecciona como consecuencia de los drivers arquitectónicos y no como punto de partida del diseño. Esto permite justificar por qué existe cada componente, qué requisito satisface, qué alternativa se evaluó y qué compromiso introduce.

1.1 Aplicación de ADD 3.0 al caso BP

ADD se aplica de forma iterativa. En el primer paso se revisan los insumos y se identifican los requisitos arquitectónicamente significativos (ASR): funcionalidad principal, atributos de calidad, restricciones y preocupaciones que pueden modificar la estructura de la solución. En el segundo paso se seleccionan los ASR que actuarán como drivers de la iteración. A partir de ellos se refinan elementos, se evalúan conceptos de diseño y se concretan decisiones.

Etapas ADD	Aplicación en BP	Resultado
1. Review Inputs	Revisar contexto, requisitos, Core, sistema de detalle, IdP, integraciones, normativa y supuestos. Identificar ASR.	Alcance, restricciones, vacíos y ASR.
2. Select Drivers	Priorizar seguridad, disponibilidad, resiliencia, consistencia, rendimiento, auditabilidad, interoperabilidad y modificabilidad.	Drivers de la iteración.
3. Select Elements to Refine	Refinar progresivamente canales, backend digital, transacciones, identidad, integración, datos y operación.	Áreas de arquitectura a diseñar.

4. Select Design Concepts	Evaluar tácticas y patrones como Multi-AZ, BFF, Cache-Aside, Event-Driven, Outbox, idempotencia y Anti-Corruption Layer.	Conceptos candidatos y alternativas.
5. Instantiate Elements	Asignar responsabilidades, interfaces y tecnologías concretas a los elementos seleccionados.	Servicios, contratos y componentes AWS.
6. Sketch Views & Decisions	Documentar las vistas C4, flujos críticos y decisiones ADR.	Arquitectura comunicable y trazable.
7. Analyze Design	Revisar HA/DR, seguridad, fallos parciales, regulación, costos y trade-offs.	Riesgos, decisiones abiertas y siguiente iteración.

1.2 Documentación y evaluación

El proceso de diseño y su documentación cumplen funciones distintas. ADD estructura el razonamiento; C4 representa el resultado mediante vistas de Contexto, Contenedores y Componentes; los ADR registran decisiones relevantes, alternativas y trade-offs; y AWS Well-Architected sirve como referencia para revisar la solución desplegada en AWS. Estos elementos se complementan y no se sustituyen entre sí.

Elemento	Uso en el documento
ADD 3.0	Método de diseño: transforma requisitos y drivers en estructuras y decisiones arquitectónicas.
C4	Modelo de comunicación: Contexto, Contenedores y Componentes para diferentes audiencias.
ADR	Registro de decisiones: conserva contexto, alternativas, justificación y compromisos.
AWS Well-Architected	Marco de revisión: contrasta seguridad, confiabilidad, operación, rendimiento, costos y sostenibilidad del diseño AWS.

1.3 Trazabilidad de decisiones

La siguiente matriz resume la cadena de razonamiento utilizada en las decisiones principales. Los valores concretos de SLA, RTO/RPO, capacidad, región y dimensionamiento se mantienen como decisiones pendientes cuando el ejercicio no aporta información suficiente.

ID	ASR / driver	Patrón o táctica	Decisión de diseño	Tecnología / mecanismo
ASR-01	Disponibilidad ante fallos	Redundancia + health checks	Capacidad distribuida entre AZ y reemplazo automático de tareas.	ECS Fargate Multi-AZ; Aurora Multi-AZ
ASR-02	Rendimiento en consultas frecuentes	Cache-Aside	Cachear únicamente información apta para consistencia eventual; el Core conserva autoridad.	ElastiCache / Redis
ASR-03	Desacoplamiento y resiliencia	Event-Driven + Queue	Separar transacción de efectos secundarios como notificación y consumidores posteriores.	EventBridge + SQS + DLQ
ASR-04	Consistencia entre estado y evento	Transactional Outbox	Persistir el cambio de negocio y la intención de publicación en la misma transacción local.	Aurora + Outbox Worker
ASR-05	Interoperabilidad con legado	Anti-Corruption Layer + Adapter	Aislar contratos digitales de protocolos, formatos y particularidades del Core/hub.	Adapters / APIs de integración
ASR-06	Autenticación segura	BFF; Authorization Code + PKCE	Integrar el IdP corporativo sin exponer tokens sensibles en la SPA y usar flujo adecuado en móvil.	IdP OAuth2/OIDC; API Gateway/BFF
ASR-07	Auditabilidad y evidencia	Append-only / inmutabilidad	Separar auditoría de negocio de logs operativos y conservar evidencia protegida.	Audit Service; S3 Object Lock; CloudTrail
ASR-08	Continuidad regional	DR con recuperación controlada	Mantener una estrategia secundaria regional cuyo nivel se cierre con BIA y RTO/RPO.	Backups/replicación; warm standby según BIA

Esta trazabilidad se detalla posteriormente en los diagramas, flujos y registros de decisión. Si un componente no puede relacionarse con un requisito, driver o preocupación arquitectónica relevante, su inclusión debe cuestionarse para evitar sobrearquitectura.

2. Alcance, requisitos y supuestos

El ejercicio solicita una plataforma de banca por Internet que permita consultar movimientos, realizar transferencias y pagos, consumir información de cliente desde dos sistemas corporativos, autenticar mediante OAuth 2.0, incorporar onboarding biométrico, registrar auditoría y notificar las operaciones a través de al menos dos mecanismos independientes. Además, exige alta disponibilidad, recuperación ante desastres, seguridad, monitoreo y auto-healing, y solicita documentar la solución con C4 hasta nivel de componentes.

2.1 Requisitos que condicionan la arquitectura

Tipo	Requisito interpretado
Funcional	Consulta de cliente, productos/movimientos, transferencias y pagos.
Integración	Core Bancario + sistema independiente de detalle de cliente; hub o mecanismo corporativo para pagos/interbancario.
Canales	SPA web y aplicación móvil multiplataforma; se deben comparar dos frameworks móviles.
Identidad	Producto corporativo existente compatible con OAuth 2.0; se debe recomendar el flujo adecuado.
Onboarding	Reconocimiento facial como parte del alta de nuevos clientes y enrolamiento posterior de credenciales.
Notificación	Dos sistemas/canales independientes como mínimo; el diseño propone e-mail y SMS, con push opcional.
Auditoría	Base de datos de auditoría que registre las acciones del cliente.
Rendimiento	Mecanismo para acelerar consultas de clientes frecuentes; se propone Cache-Aside.
Calidad	HA, tolerancia a fallos, DR, seguridad, monitoreo, excelencia operativa y auto-healing.
Documentación	C4 Contexto, Contenedores y Componentes, más los diagramas auxiliares que soporten la justificación.

2.2 Supuestos que deben confirmarse antes de producción

Tema	Supuesto / impacto
Carga y concurrencia	No se informan TPS ni usuarios concurrentes. Se asume escalamiento horizontal y se difiere el sizing a una prueba de carga.
SLA / BIA	No se entregan objetivos formales. Como referencia de diseño se usa 24x7 para canal digital; RTO/RPO deben salir del BIA del banco.
Core	El Core continúa siendo la fuente autoritativa de saldos, movimientos y productos.
Pagos BCE	La banca digital no se conecta directamente al BCE; utiliza el hub/mecanismo corporativo vigente de BP.
IdP	Se asume soporte de OIDC, Authorization Code, PKCE, MFA/step-up y aprovisionamiento de usuarios.
Residencia y tratamiento de datos	No se asume que una región extranjera sea aceptable por defecto; Legal, DPO, Riesgos y Seguridad deben validar el modelo de tratamiento y el rol contractual de AWS/proveedores.
Madurez operativa	Si BP no dispone de capacidades DevSecOps/SRE para varios despliegues independientes, los servicios pueden consolidarse inicialmente sin romper sus límites lógicos.

3. Drivers arquitectónicos y criterios de calidad

Con la metodología definida en la Sección 1, los requisitos del caso se filtran para identificar aquellos que son arquitectónicamente significativos y se convierten en drivers priorizados. Estos drivers guían la selección de patrones, tácticas y alternativas antes de asignar tecnologías concretas. El objetivo es mantener trazabilidad entre necesidad de negocio, atributo de calidad y decisión técnica.

Driver	Prioridad	Justificación
Seguridad y privacidad	Muy alta	Datos financieros, identidad y biometría; un incidente tiene impacto regulatorio y reputacional.
Consistencia e idempotencia	Muy alta	Una operación monetaria duplicada es más grave que una respuesta lenta.
Disponibilidad y resiliencia	Muy alta	El canal debe soportar fallos parciales, pérdida de tasks/AZ y dependencias degradadas.
Auditabilidad	Muy alta	Se requiere trazabilidad de usuario, acción, resultado, referencia y correlación.
Interoperabilidad	Alta	La solución depende de Core, detalle, IdP, proveedores, hub de pagos y canales de notificación.
Rendimiento	Alta	Las consultas digitales requieren latencia predecible sin sobrecargar los legados.
Modificabilidad	Alta	Proveedores, contratos y reglas cambian; los cambios deben quedar localizados.
Costo y operabilidad	Alta	No se introduce complejidad operativa sin un beneficio que pueda justificarse.

Atributo	Escenario verificable
Disponibilidad	Si falla una task o una AZ, el tráfico se redirige a instancias sanas y el canal continúa sin intervención manual.
Resiliencia	Si el Core supera el timeout, la llamada se corta, se evita una tormenta de retries y se devuelve un estado controlado.
Idempotencia	Repetir una transacción con la misma Idempotency-Key no genera un segundo efecto monetario.
Seguridad web	Los tokens OAuth no quedan disponibles al JavaScript de la SPA; el BFF conserva los tokens del lado servidor.
Auditoría	Toda acción sensible genera un registro correlacionado; los eventos críticos de modificación se publican desde un Outbox.
DR	La plataforma puede conmutar a una región secundaria dentro de los objetivos aprobados por el BIA.

4. Arquitectura recomendada y decisiones maestras

La solución se plantea como una arquitectura distribuida orientada a servicios. Las operaciones que necesitan una respuesta inmediata usan integración síncrona; las notificaciones, auditoría derivada y otros efectos secundarios se desacoplan mediante mensajería asíncrona. Los servicios que requieren autonomía operativa se despliegan de forma independiente en ECS Fargate, con contratos y propiedad de datos claramente definidos. AWS es la plataforma de ejecución, no el estilo arquitectónico. Se mantienen pocos límites de servicio para evitar fragmentación innecesaria y el riesgo de construir un monolito distribuido.

Área	Decisión
Runtime	Amazon ECS sobre Fargate, Multi-AZ. EKS se descarta como opción base porque el ejercicio no aporta un requisito que justifique la complejidad adicional de Kubernetes.
Frontend web	React + TypeScript, contenido estático en S3/CloudFront y Web BFF del lado servidor.
Móvil	Flutter como opción base; React Native queda como alternativa si la capacidad interna en React/TypeScript es determinante.
Servicios principales	Customer Query, Movement Query y Transaction Service, alineados con las tres capacidades indicadas en el ejercicio.
Servicios de soporte	Onboarding/KYC, Notification y Audit. Se separan por sus controles, integración y ciclos de cambio distintos.
Integración legado	Adapters / Anti-Corruption Layer para evitar que el dominio dependa de SOAP, formatos batch, contratos legacy o particularidades del mecanismo interbancario.
Mensajería	EventBridge para enrutamiento de eventos; SQS por consumidor; DLQ para mensajes que no pueden procesarse tras los retries definidos.
Datos	Persistencia propiedad de cada capacidad que la necesita; no se permite acceso cruzado a tablas. Redis se usa solo como caché.
Auditoría	Audit Service + base de auditoría + archivo inmutable en S3 Object Lock; CloudTrail se mantiene para el plano de control AWS.

4.1 Elección del framework móvil

Opción	Fortalezas	Consideraciones	Criterio de elección
Flutter	Código y UI consistentes entre iOS/Android; buen rendimiento y control del diseño; SDKs nativos accesibles mediante plugins.	Requiere experiencia Dart/Flutter y validación de plugins bancarios/KYC.	Recomendado como opción base si BP no tiene una estandarización previa.
React Native	Aprovecha React/TypeScript; ecosistema amplio; reduce curva si el equipo web y móvil comparten capacidades.	Dependencia mayor de módulos nativos en ciertos casos y disciplina adicional para consistencia entre plataformas.	Preferible si BP ya posee una práctica madura de React/TypeScript móvil.

Para el ejercicio se selecciona Flutter como opción base. En un proyecto real, esta decisión debe contrastarse con el talento disponible, los componentes móviles que BP ya tenga desarrollados y el soporte de los SDK de seguridad y KYC. Si la organización ya cuenta con una práctica madura en React/TypeScript, React Native puede resultar más conveniente.

5. C4 Nivel 1 - Contexto

Esta vista se presenta la Banca Digital BP como un único sistema y muestra su relación con el cliente, las áreas de control y los sistemas externos. No incluye bases de datos ni detalles de despliegue.

C4 Nivel 1 — Contexto del sistema

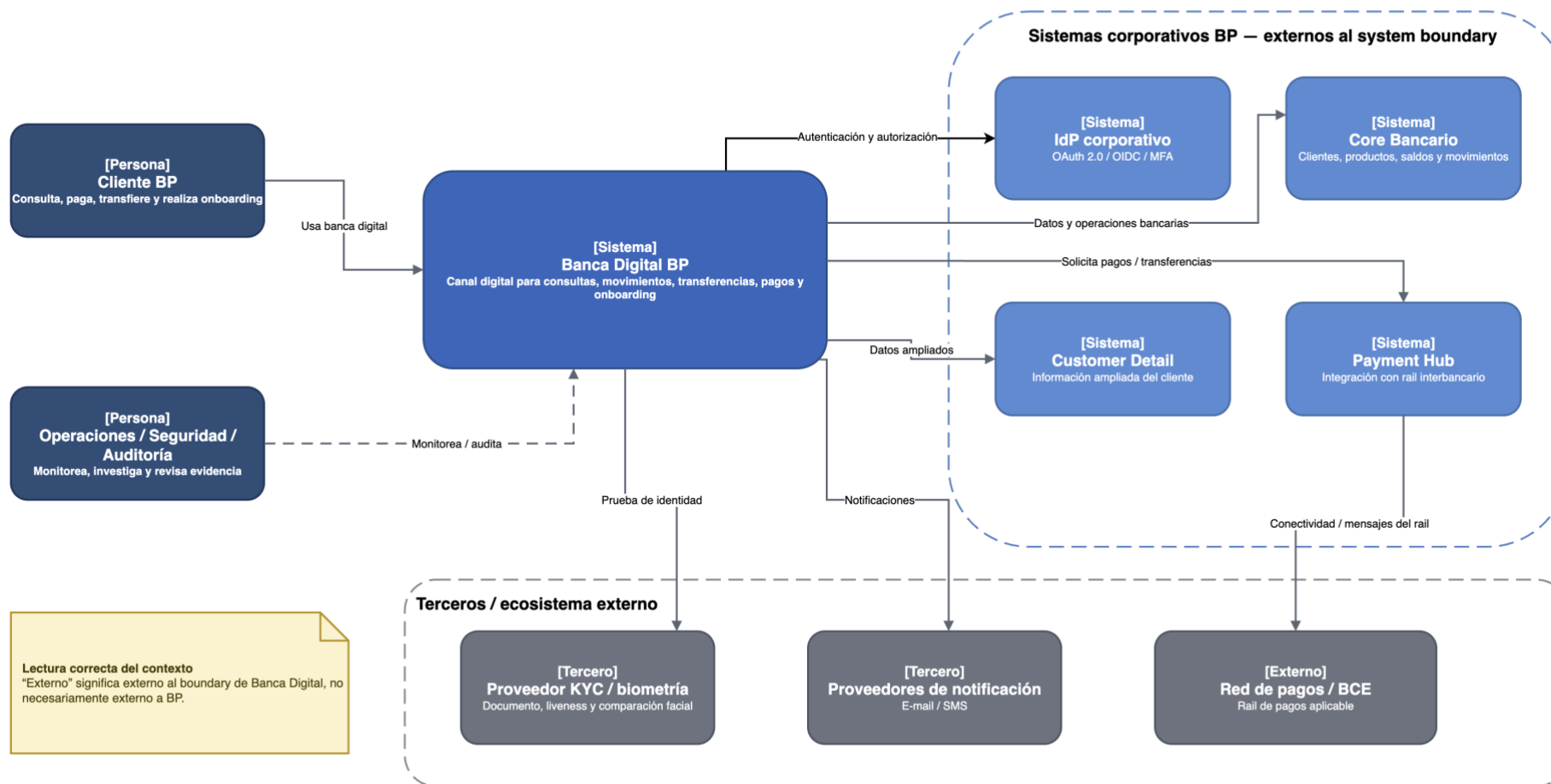


Figura 1. C4 Nivel 1 - Contexto de la Banca Digital BP.

Lectura ejecutiva: la banca digital no sustituye al Core. Actúa como una capa de experiencia e integración que consume las capacidades corporativas y encapsula proveedores externos.

6. C4 Nivel 2 - Contenedores

La vista de contenedores muestra las aplicaciones, servicios, almacenes de datos y mecanismos de mensajería que forman la solución. Cada servicio conserva contratos y propiedad de datos propios; compartir tablas no se utiliza como mecanismo de integración. Para facilitar la lectura, el Nivel 2 se divide en cuatro subfiguras: 2A canales y acceso, 2B servicios de aplicación, 2C datos y mensajería y 2D integraciones externas mediante Anti-Corruption Layer. Los diagramas de secuencia se reservan para explicar el comportamiento temporal.

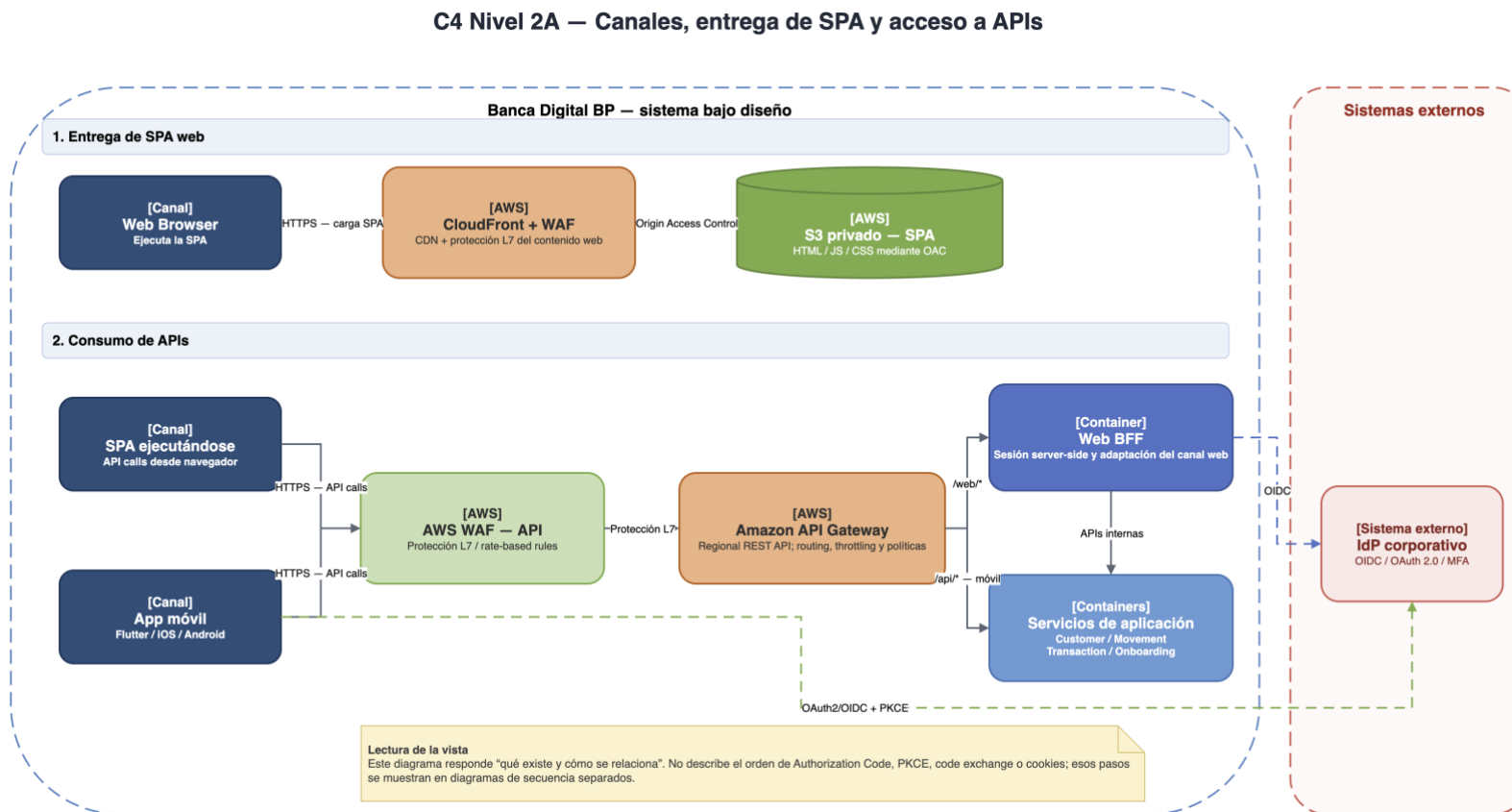


Figura 2A. C4 Nivel 2 - Canales, entrega de SPA y acceso a APIs.

C4 Nivel 2B — Servicios de aplicación (Containers)

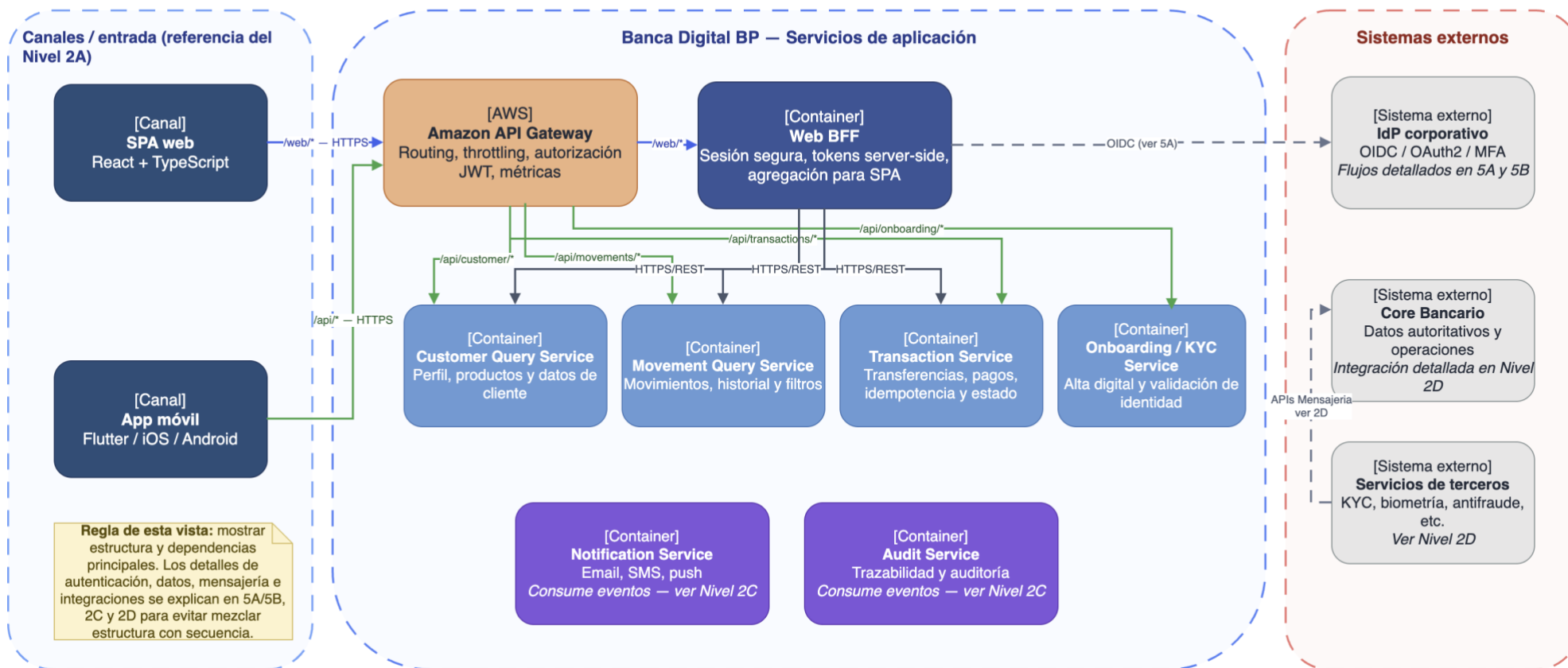


Figura 2B. C4 Nivel 2 - Servicios de aplicación.

C4 Nivel 2C — Datos y mensajería

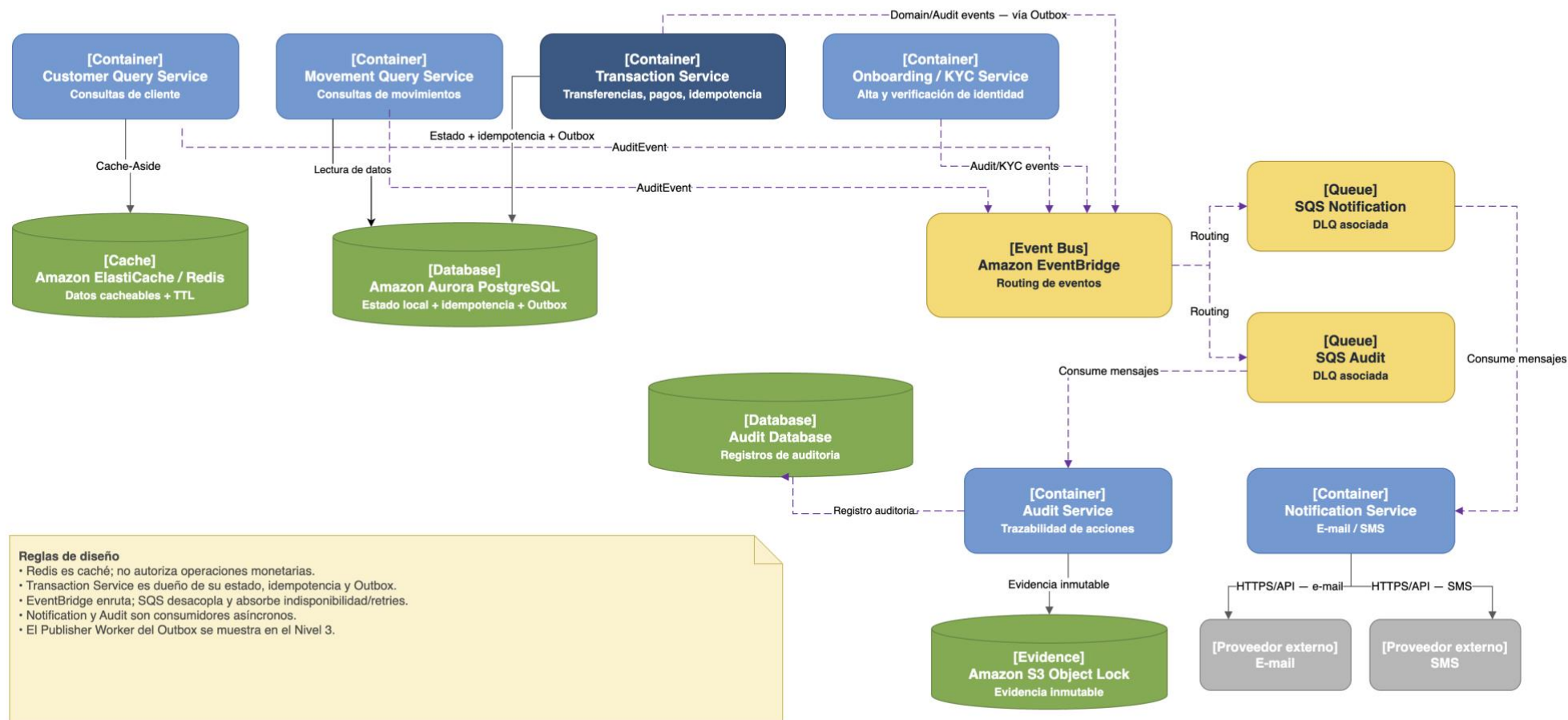


Figura 2C. C4 Nivel 2 - Datos y mensajería.

C4 Nivel 2D — Vista complementaria de Integraciones externas y Anti-Corruption Layer (ACL)

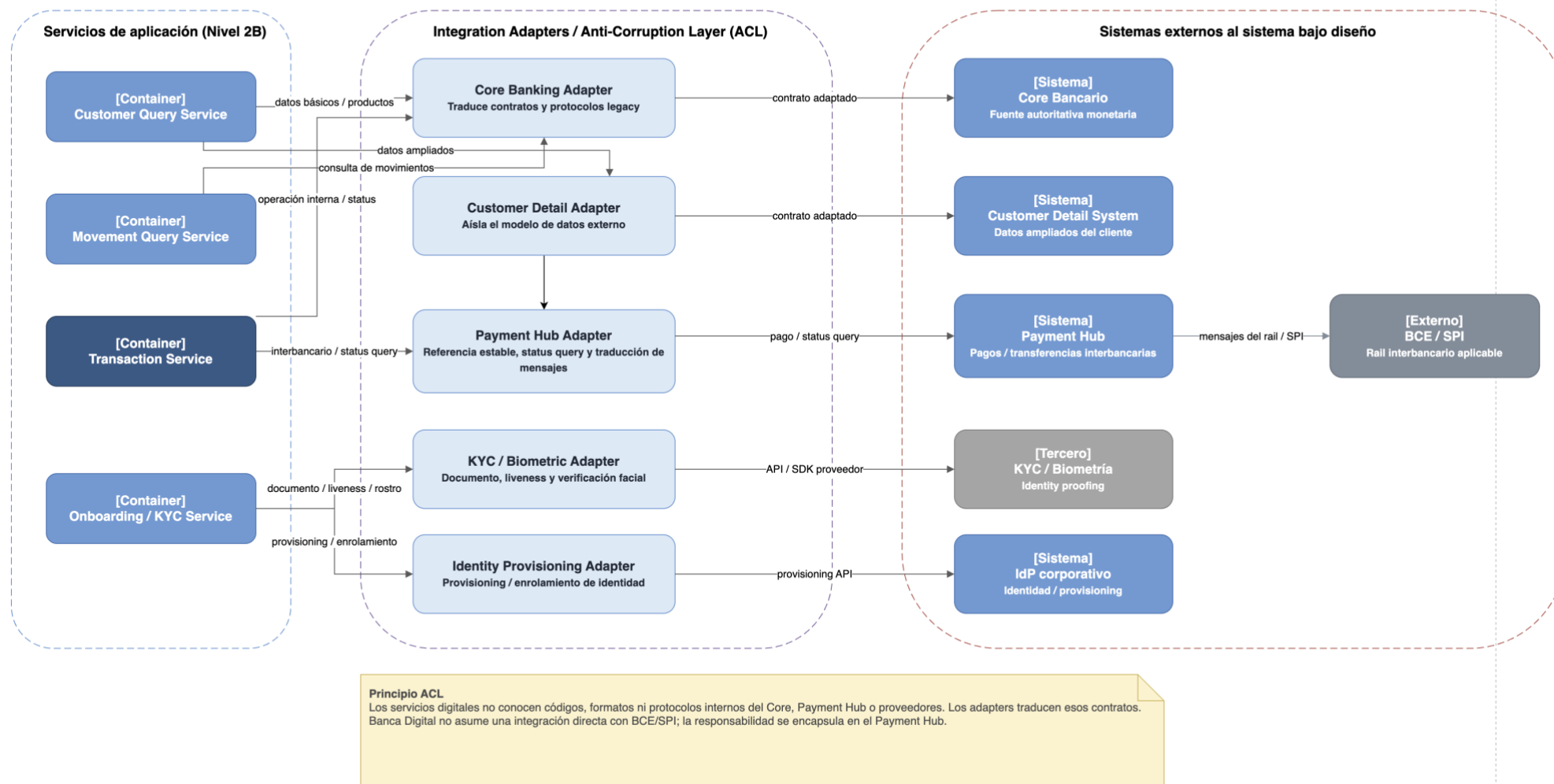


Figura 2D. C4 Nivel 2 - Integraciones externas y Anti-Corruption Layer.

7. C4 Nivel 3 - Componentes

En C4, el nivel de componentes abre un contenedor concreto. Para cubrir los dos riesgos más relevantes del ejercicio se detallan Transaction Service y Onboarding/KYC Service. El primero concentra consistencia monetaria e idempotencia; el segundo concentra privacidad, biometría e identidad.

C4 Nivel 3 — Transaction Service

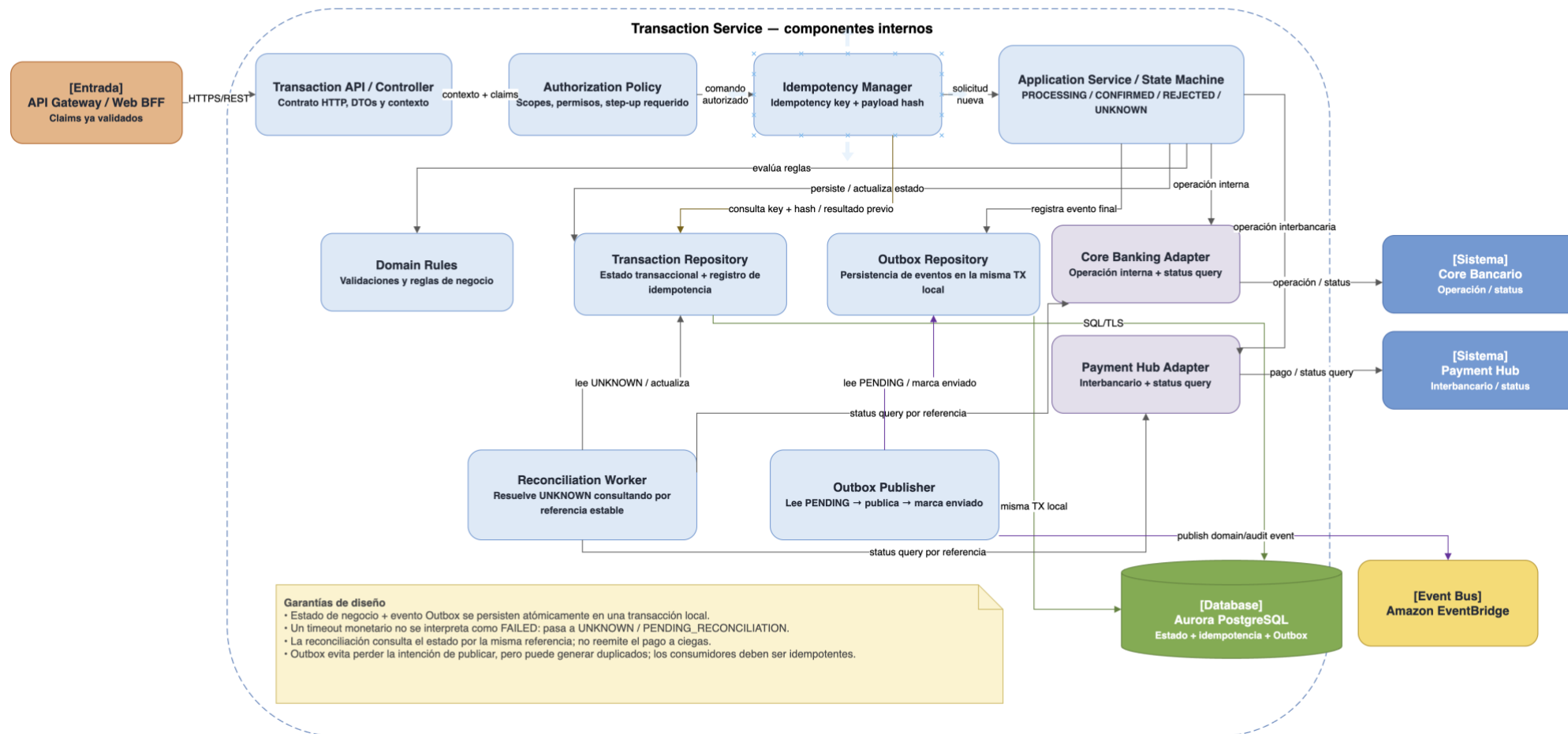


Figura 3. Componentes internos del Transaction Service.

C4 Nivel 3 — Onboarding / KYC Service

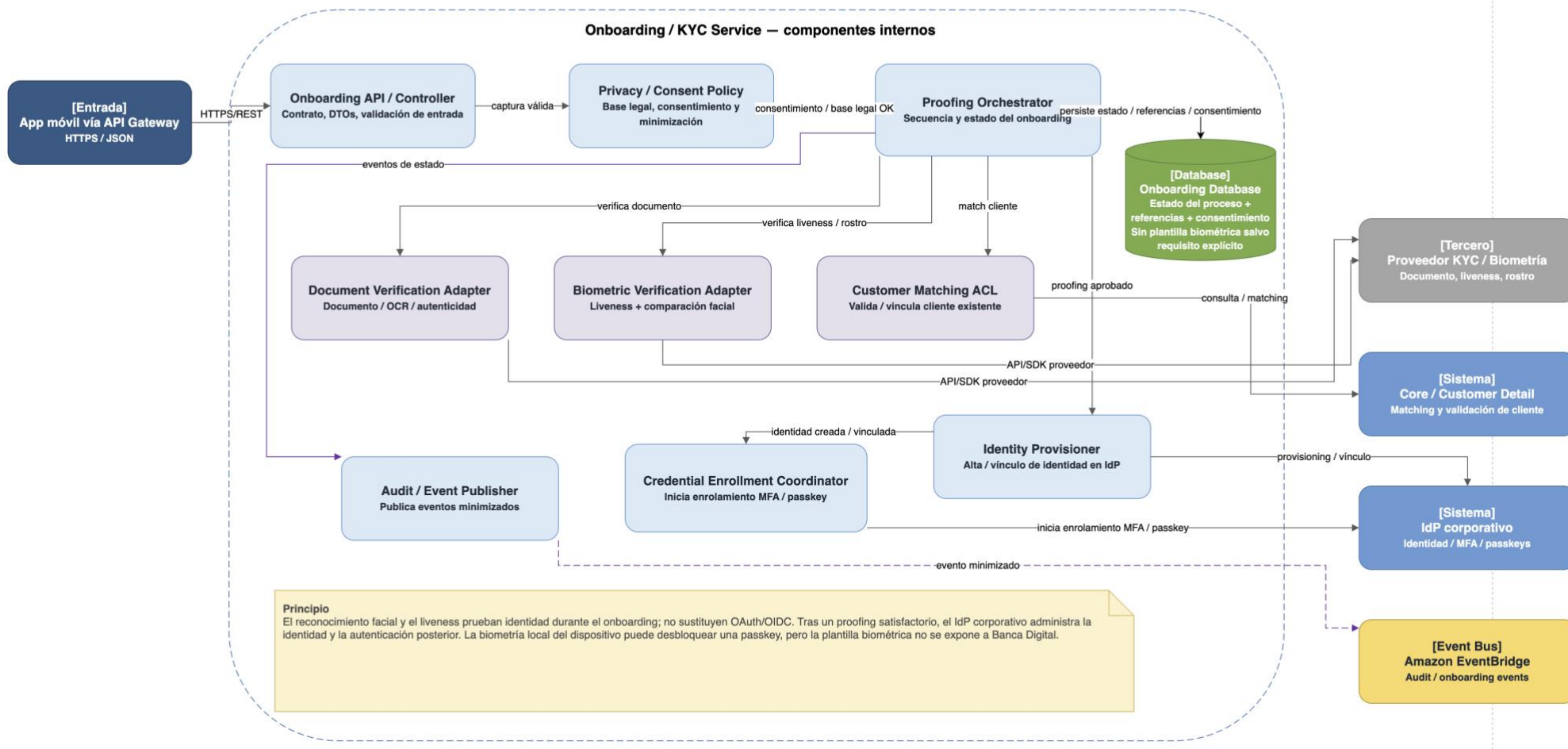


Figura 4. Componentes internos del Onboarding / KYC Service.

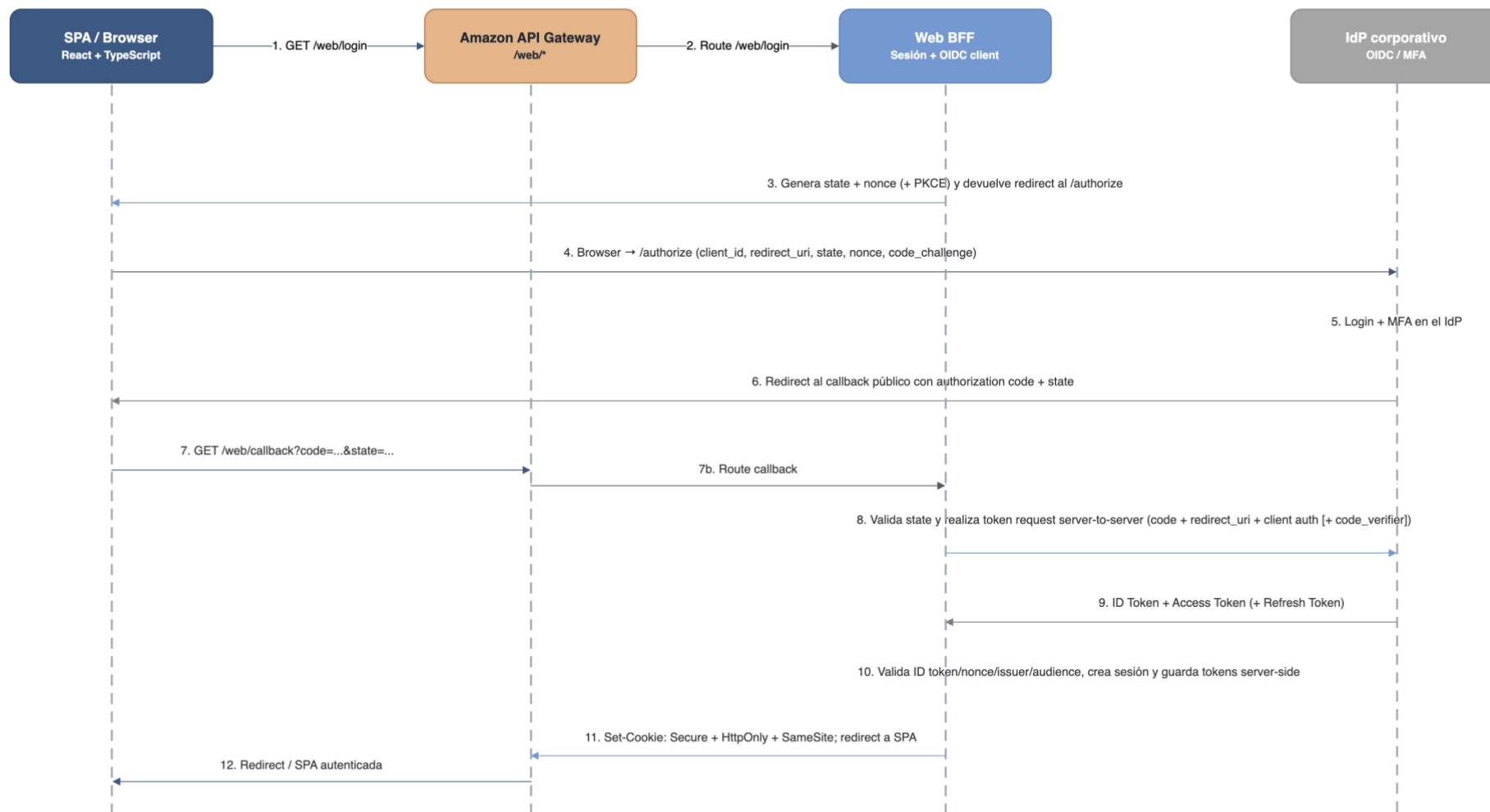
8. Flujos críticos

8.1 Autenticación web: SPA + BFF

1. La SPA invoca el endpoint de inicio de sesión del Web BFF.
2. El BFF inicia Authorization Code + PKCE contra el IdP corporativo mediante OpenID Connect.
3. El IdP autentica al cliente y aplica MFA o step-up cuando la política de riesgo lo requiere.
4. El authorization code retorna al BFF; el BFF intercambia el código y mantiene access/refresh tokens en el servidor.
5. El navegador recibe únicamente una cookie de sesión protegida con Secure, HttpOnly y SameSite; los tokens OAuth no quedan expuestos al JavaScript de la SPA.
6. El BFF añade el token adecuado cuando invoca APIs protegidas.

La decisión se apoya en RFC 10017. El documento presenta tres patrones para aplicaciones OAuth en navegador y los ordena de mayor a menor seguridad; BFF aparece como la alternativa más segura de las tres. Para un canal bancario, la contrapartida —un componente server-side adicional y un salto de red— es razonable frente a la reducción de exposición de los tokens en el navegador.

Secuencia 05A — Autenticación Web con Web BFF



Resultado

La SPA no almacena Access/Refresh Tokens. Mantiene una cookie de sesión protegida y consume /web/* a través del BFF. El BFF conserva los tokens server-side y actúa en nombre del usuario hacia las APIs internas.

Figura 5A. Secuencia de autenticación Web SPA + BFF.

8.2 Autenticación móvil

1. La aplicación abre el navegador del sistema (external user-agent) para autenticarse; no captura credenciales del IdP dentro de un WebView embebido.
2. Como cliente público, utiliza Authorization Code + PKCE con S256.
3. Los tokens se almacenan mediante los mecanismos seguros de la plataforma (Keychain, Keystore o Secure Enclave, según aplique) y con una vida útil limitada.
4. Para el reingreso se recomienda enrolar una passkey/FIDO2. La huella o Face ID del dispositivo puede desbloquear la credencial local; la plantilla biométrica del equipo no se entrega al banco.
5. Las operaciones sensibles pueden exigir autenticación reforzada (step-up) incluso cuando la sesión ya está activa.

Secuencia 05B — Autenticación móvil con Authorization Code + PKCE

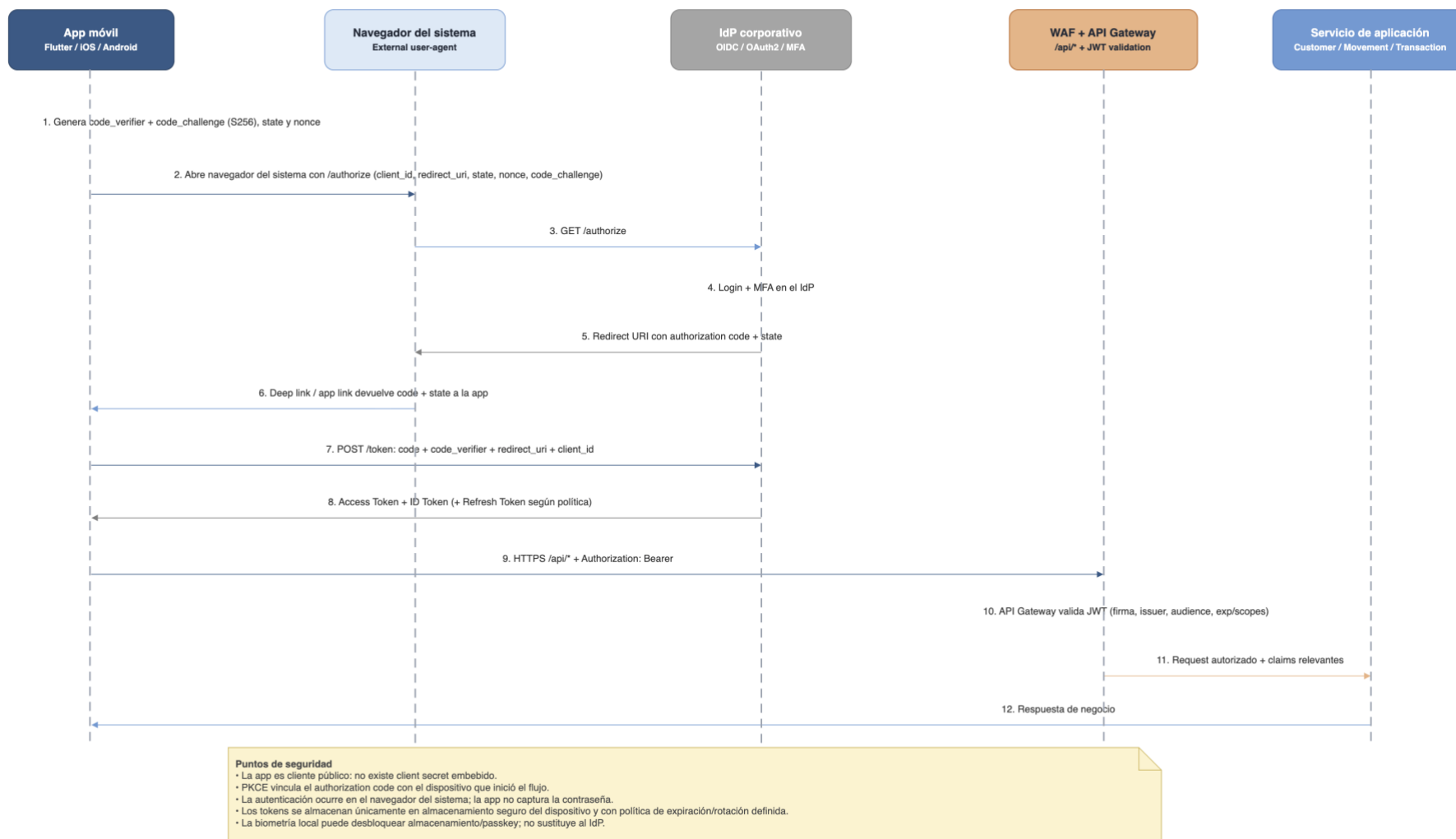


Figura 5B. Secuencia de autenticación móvil con Authorization Code + PKCE.

8.3 Onboarding biométrico

Paso	Control
1. Inicio	Presentar aviso de privacidad y condiciones; registrar evidencia de la base aplicable al tratamiento.
2. Documento	Captura y verificación documental con minimización de datos.
3. Liveness	Verificar presencia de persona real; rate limiting y controles antifraude.
4. Comparación facial	Comparar rostro contra la fuente autorizada; definir revisión humana para excepciones.
5. Cruce con BP	Validar información contra Core / sistema de detalle mediante ACL.
6. Alta de identidad	Crear o activar el usuario en el IdP corporativo una vez aprobado el KYC.
7. Enrolamiento	Registrar passkey u otro factor fuerte y mantener un mecanismo de recuperación controlado.
8. Auditoría y retención	Conservar solo evidencia y biometría estrictamente necesarias conforme a finalidad, evaluación de impacto y política aprobada.

Criterio de diseño: el reconocimiento facial del onboarding es una prueba de identidad. OAuth/OIDC gestiona la autenticación y autorización de las sesiones posteriores. Separar ambas funciones evita que una decisión biométrica quede mezclada con el mecanismo de emisión de tokens.

8.4 Transacción: idempotencia, estado y Outbox

Secuencia 05C — Transacción exitosa

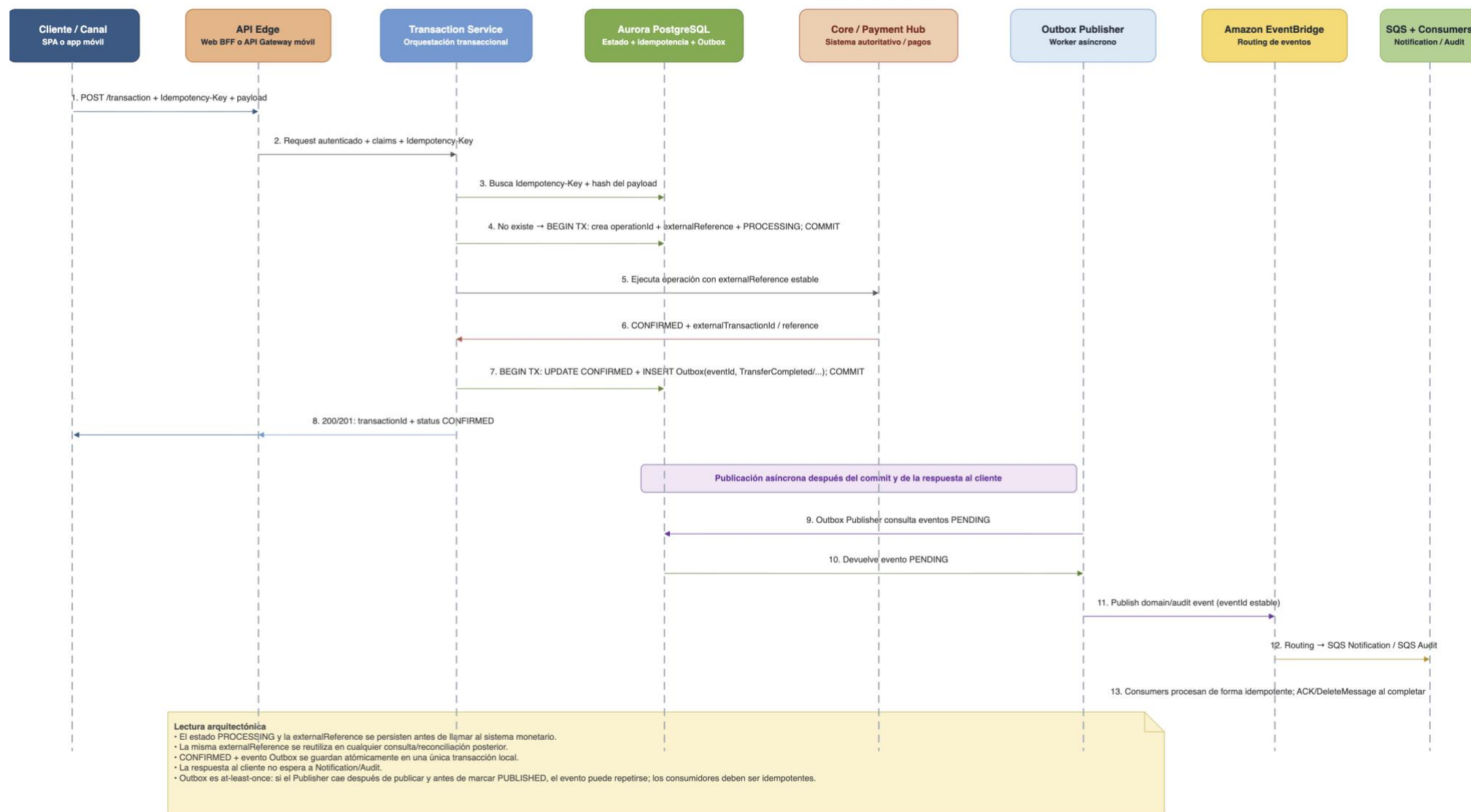


Figura 5C. Secuencia de transacción exitosa con idempotencia, estado durable y Outbox.

Si la llamada al Core o al hub termina en timeout, el resultado se clasifica como UNKNOWN/PENDING_RECONCILIATION. No se reintenta la instrucción monetaria a ciegas. El sistema consulta o reconcilia usando una referencia de negocio estable. Esta regla evita convertir un problema de red en una duplicidad financiera.

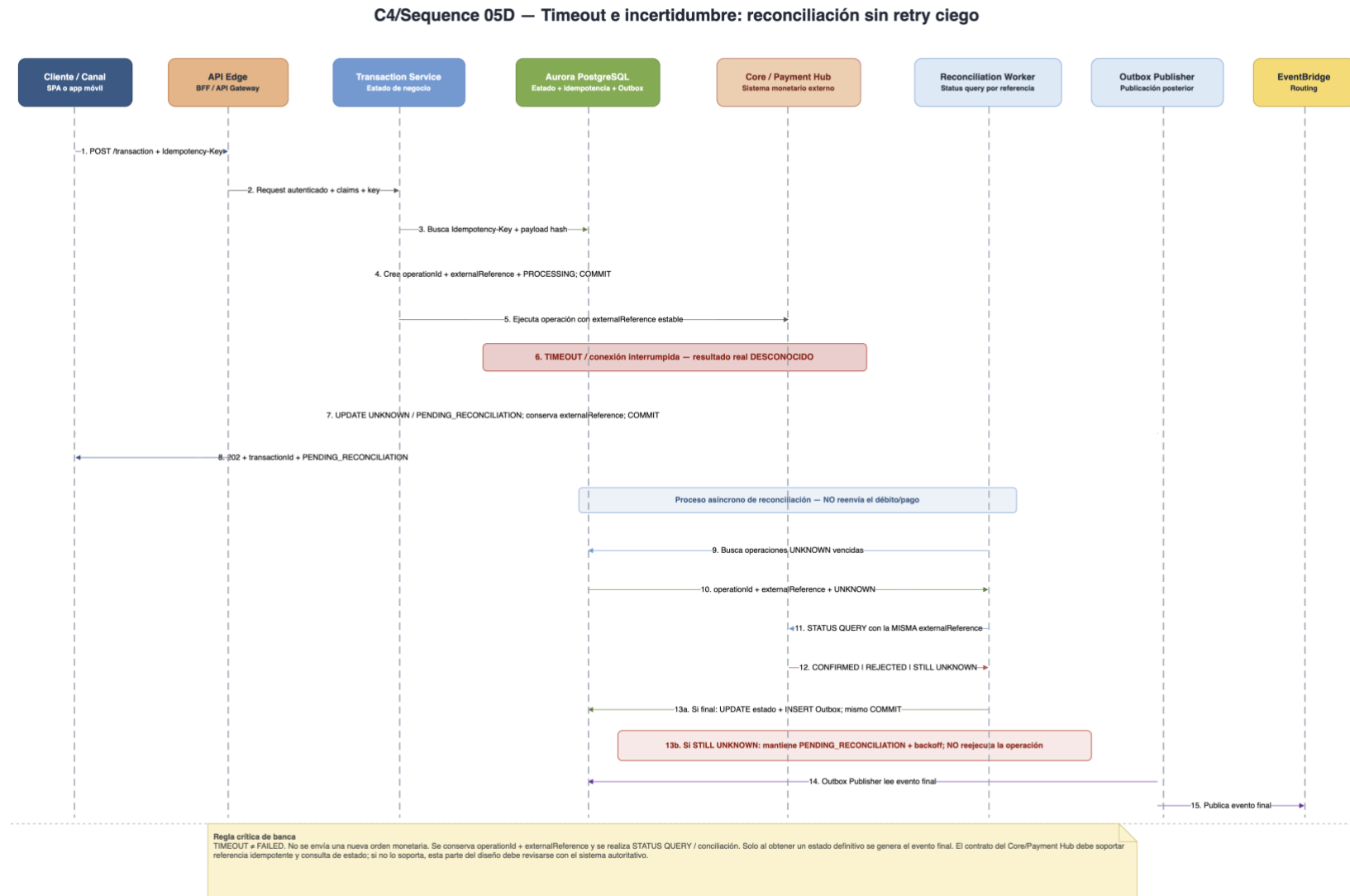


Figura 5D. Secuencia de timeout y reconciliación sin retry monetario ciego.

En una operación interbancaria, ACCEPTED o PENDING significa que BP aceptó la orden, no que el mecanismo del Banco Central ya la liquidó. La interfaz debe mostrar el estado real y actualizarlo cuando exista confirmación o reconciliación.

8.5 Integración interbancaria

La banca digital no debe implementar directamente las particularidades del BCE. Transaction Service utiliza un adaptador hacia el hub de pagos de BP; ese hub concentra formatos, referencias, ventanas operativas, reconciliación y contingencia del mecanismo interbancario aplicable. El SPI del BCE, por ejemplo, opera con participantes, reglas de conectividad y condiciones operativas definidas por el Banco Central.

- Registrar la instrucción con un identificador estable antes de enviarla al hub.
- No inferir liquidación por un HTTP 200 o por una confirmación técnica del adaptador.
- Reconciliar por referencia de negocio y conservar evidencia de la instrucción y sus cambios de estado.
- No ejecutar una compensación automática sobre una operación irrevocable o ya liquidada; cualquier reverso o compensación debe respetar las reglas de negocio y de la red de pagos aplicable.

9. Datos, caché y auditoría

9.1 Propiedad de datos y consistencia

Dato	Fuente autoritativa	Regla de uso
Cliente básico / productos	Core Bancario	Customer Query puede cachear datos permitidos con TTL.
Cliente detallado	Sistema de detalle	Customer Query puede cachear atributos de lectura, con minimización.
Movimientos / saldo	Core / ledger	Movement Query puede cachear histórico. El saldo usado para autorizar una operación se obtiene de la fuente autoritativa.
Estado de transacción / idempotencia / outbox	Transaction Service	Aurora privado del servicio. Otros servicios consumen API/eventos, no tablas.
Auditoría de negocio	Audit Service	Base de consulta + archivo inmutable según política de retención.
Biometría de onboarding	KYC / proveedor según modelo contractual	Retención mínima; controles reforzados y política de borrado.

9.2 Clientes frecuentes: patrón Cache-Aside

Diagrama 06 — Cache-Aside para consultas de cliente

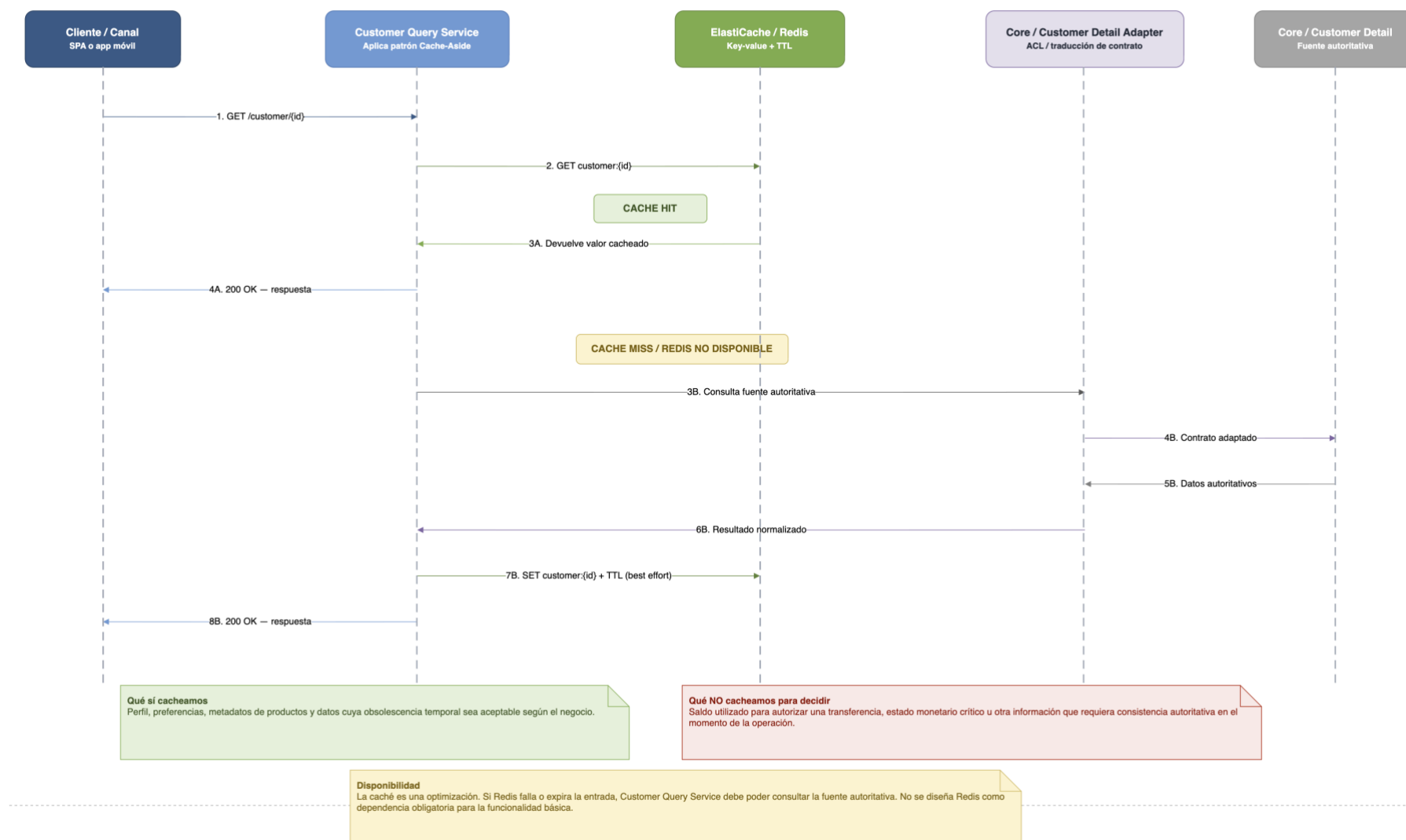


Figura 6. Cache-Aside para lecturas frecuentes sin convertir Redis en fuente de verdad.

Si el dato está vigente en la caché, el servicio lo devuelve sin consultar al sistema de origen. Si no existe o expiró, consulta la fuente autoritativa, responde al cliente y guarda una copia temporal con TTL. Secretos, tokens y datos cuya obsolescencia pueda afectar una decisión financiera no deben depender de la caché.

9.3 Auditoría

Plano	Contenido	Tecnología / patrón
Auditoría de negocio	Usuario/cliente, acción, recurso, resultado, fecha/hora, referencia de sesión/dispositivo, transaction ID, correlation/trace ID. Se evitan secretos y payloads completos sensibles.	Audit Service + SQS + base de auditoría; eventos críticos de modificación salen de Outbox.
Archivo de evidencia	Eventos consolidados sujetos a retención e integridad.	Amazon S3 Object Lock + KMS, conforme a política aprobada.
Plano AWS	Cambios IAM, llamadas de API, consola y configuración.	AWS CloudTrail + AWS Config + Security Hub.
Logs operativos	Errores, latencia y métricas técnicas con PII enmascarada.	CloudWatch + OpenTelemetry/ADOT + SIEM corporativo.

CloudTrail no reemplaza la auditoría bancaria. Registra actividad del plano AWS; el banco necesita además una bitácora de negocio que explique qué hizo el cliente, sobre qué operación y cuál fue el resultado.

10. Resiliencia y consistencia

Táctica / patrón	Aplicación	Criterio
Timeout	Toda dependencia remota	Siempre acotado; evita que una dependencia lenta consuma indefinidamente los recursos del servicio.
Retry + backoff + jitter	Lecturas y operaciones confirmadamente reintentables	Pocos intentos. No aplica como retry ciego a una instrucción monetaria con resultado desconocido.
Circuit breaker	Core, detalle, KYC y notificaciones	Corta rápidamente una dependencia degradada y evita amplificar la falla.
Bulkhead	Pools/colas por dependencia	Aísla saturación y evita que un proveedor derribe todo el canal.
Idempotency-Key	Transferencias/pagos	La misma solicitud lógica no produce un segundo efecto.
Transactional Outbox	Eventos críticos	Estado y evento quedan confirmados en la misma transacción local; la publicación se realiza después.
DLQ	Consumidores asíncronos	Aísla mensajes que no pueden procesarse y habilita replay controlado.
Saga	Solo si aparece una transacción multi-sistema con compensaciones válidas	No se incorpora por defecto; no toda operación bancaria se puede "deshacer".
Consistencia eventual	Notificaciones, analítica y vistas derivadas	Aceptable con trazabilidad; no se usa para afirmar un saldo disponible no confirmado por el Core.

11. Despliegue AWS, Well-Architected, alta disponibilidad y DR

Las Figuras 7A, 7B y 7C separan tres preocupaciones distintas: gobierno de la plataforma, operación de la región primaria y recuperación ante una caída regional. La vista de gobierno incluye el modelo multi-account, segregación de seguridad y logs, guardrails, IaC/CI-CD y FinOps. La región AWS no se considera cerrada: antes de producción BP debe medir p50/p95/p99 desde sus carriers y comparar las regiones candidatas por latencia, servicios disponibles, costo, continuidad y cumplimiento.

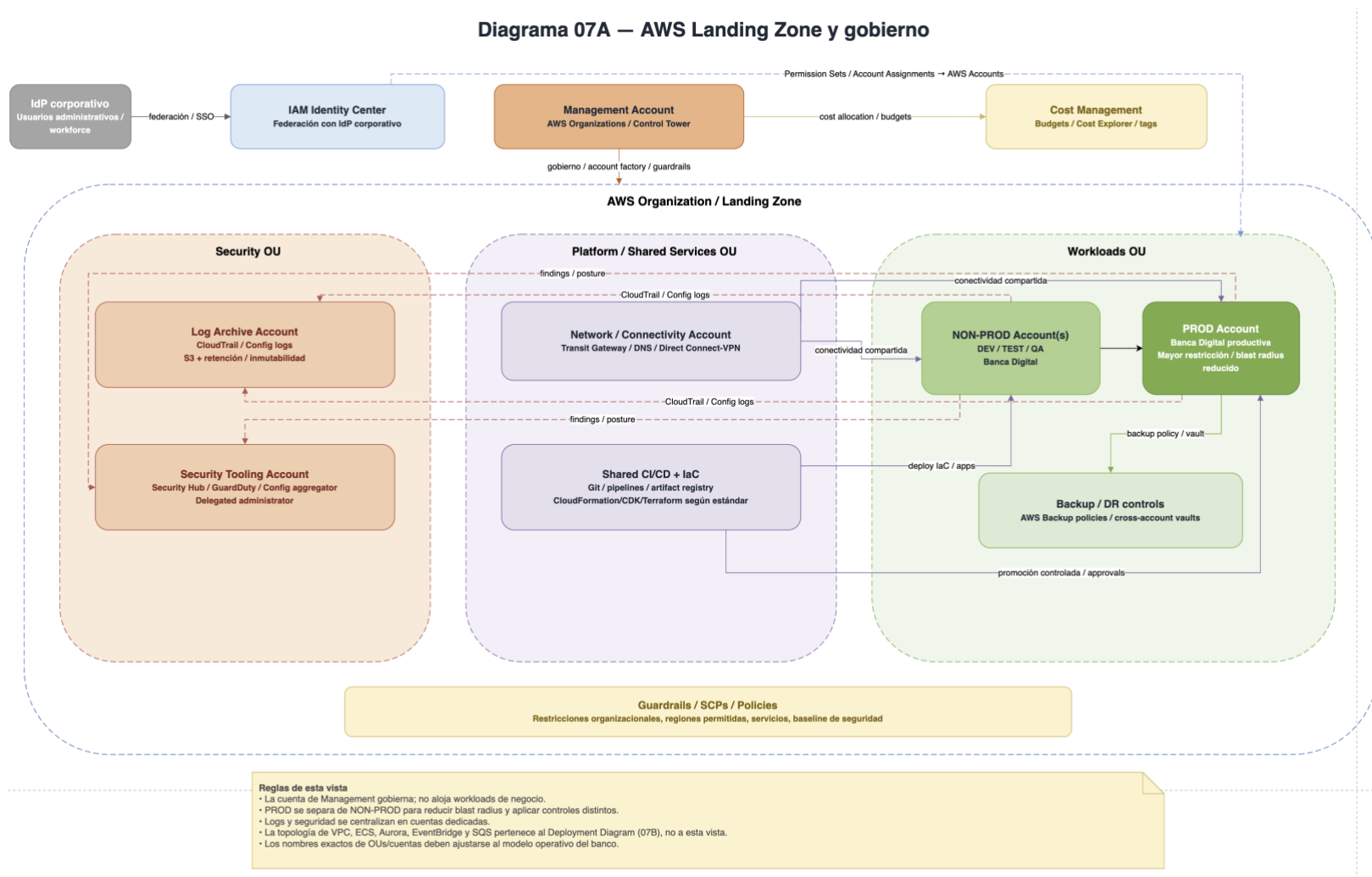


Figura 7A. Vista de despliegue - gobierno AWS Well-Architected y modelo multi-account.

Diagrama 07B — Deployment de la región primaria

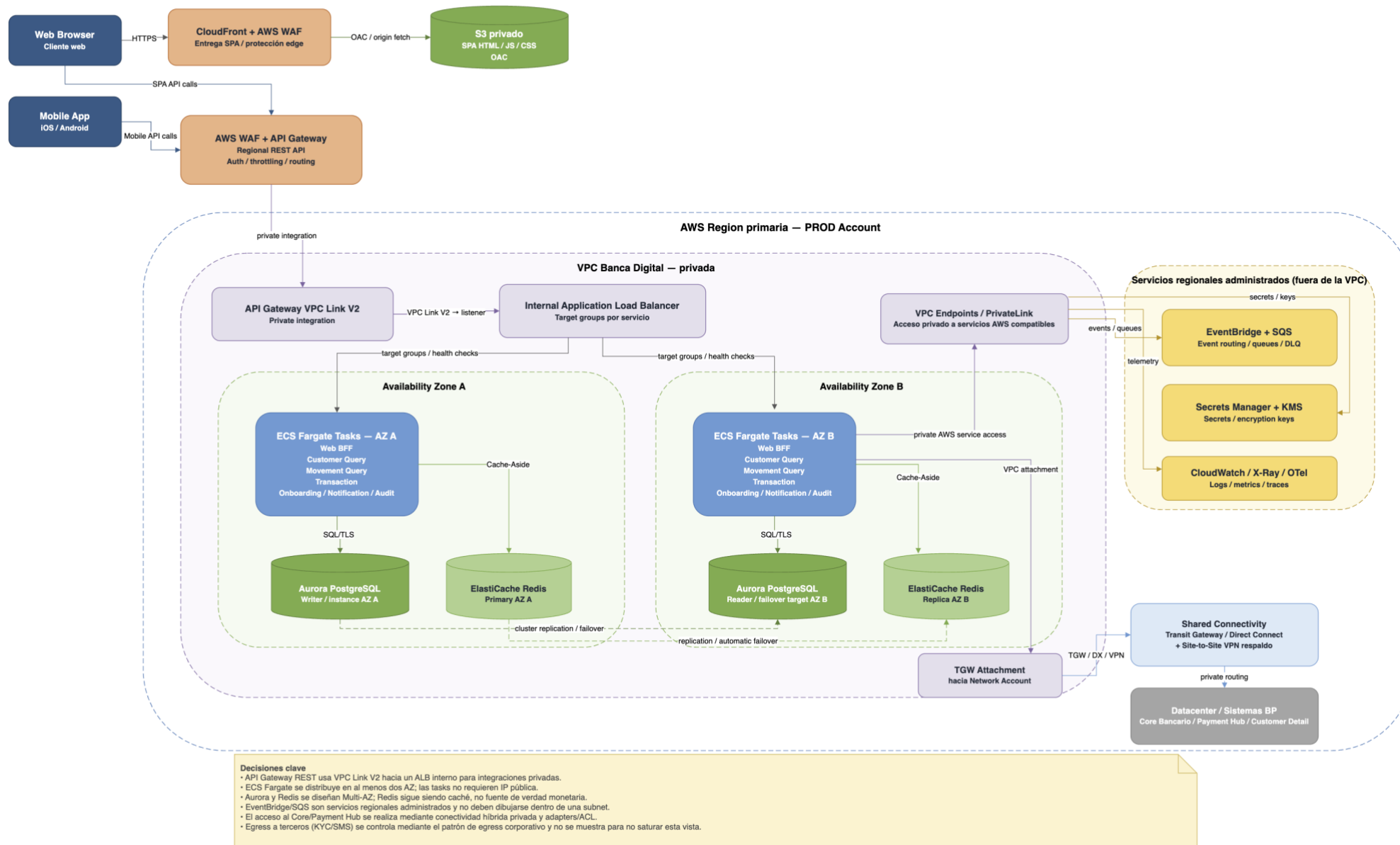


Figura 7B. Vista de despliegue - región primaria, Multi-AZ y conectividad híbrida.

Diagrama 07C — Disaster Recovery: Warm Standby Multi-Region

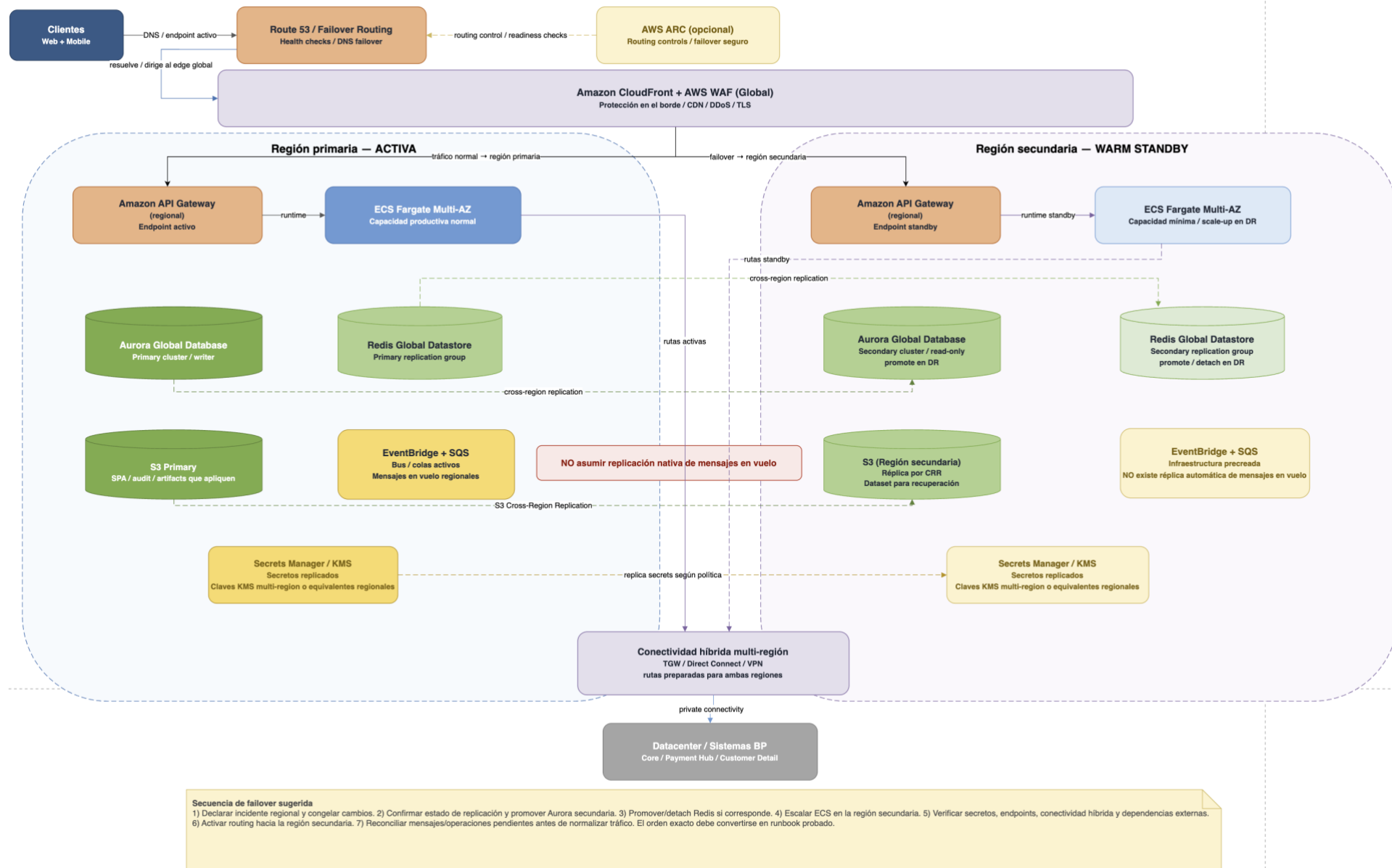


Figura 7C. Vista de despliegue - recuperación ante desastres con warm standby regional.

11.1 Estrategia de continuidad

Mecanismo	Diseño
Multi-AZ	ECS Fargate distribuido como mínimo en 2 AZ. Evaluar una tercera AZ para servicios críticos si el BIA, la disponibilidad requerida y el costo lo justifican. Aurora y Redis se configuran para alta disponibilidad Multi-AZ.
Conectividad híbrida	Dos caminos privados mediante Direct Connect/Hosted Connection con rutas físicas y proveedores diversos cuando sea viable; VPN IPSec como respaldo.
Auto-healing	ECS reemplaza tasks no saludables y Auto Scaling ajusta capacidad. Managed services reducen operación de infraestructura.
Warm standby regional	Stack funcional reducido en segunda región, infraestructura como código y replicación/backup según el RPO aprobado.
Pruebas	Pruebas de restauración, ejercicios de failover y simulacros periódicos. Un DR que no se prueba no debe considerarse una capacidad real.

Este documento no fija valores de RTO ni RPO porque el ejercicio no los proporciona. El BIA del banco debe definirlos antes de cerrar la estrategia de segunda región, la capacidad de warm standby, la tecnología de replicación y los procedimientos de recuperación.

11.3 Gobierno multi-account y entrega

Para producción se propone integrar Banca Digital BP en la Landing Zone corporativa, apoyada en AWS Organizations y, cuando aplique, AWS Control Tower. Como modelo base se separan al menos las cuentas de Security, Log Archive, servicios compartidos/red, PROD y NON-PROD. Si BP ya dispone de una Landing Zone institucional, debe reutilizarse en lugar de crear una estructura paralela.

La infraestructura debe desplegarse como código. CloudFormation o AWS CDK son opciones AWS-native adecuadas, sin impedir el uso de Terraform u otra herramienta si ya existe un estándar corporativo. El pipeline de CI/CD debe incluir pruebas, controles de seguridad y despliegues reproducibles, de modo que la misma definición sirva para reconstrucción, DR y auditoría de cambios.

12. Seguridad y observabilidad

Para un canal bancario, seguridad y observabilidad deben diseñarse de forma conjunta. La seguridad se aplica por capas: identidad, sesión, APIs, red, datos, aplicación y gobierno, mientras que la observabilidad permite seguir una operación de extremo a extremo mediante logs, métricas y trazas correlacionadas. El objetivo no es recolectar más datos, sino contar con la evidencia técnica necesaria para detectar, diagnosticar y responder a fallos sin exponer información sensible.

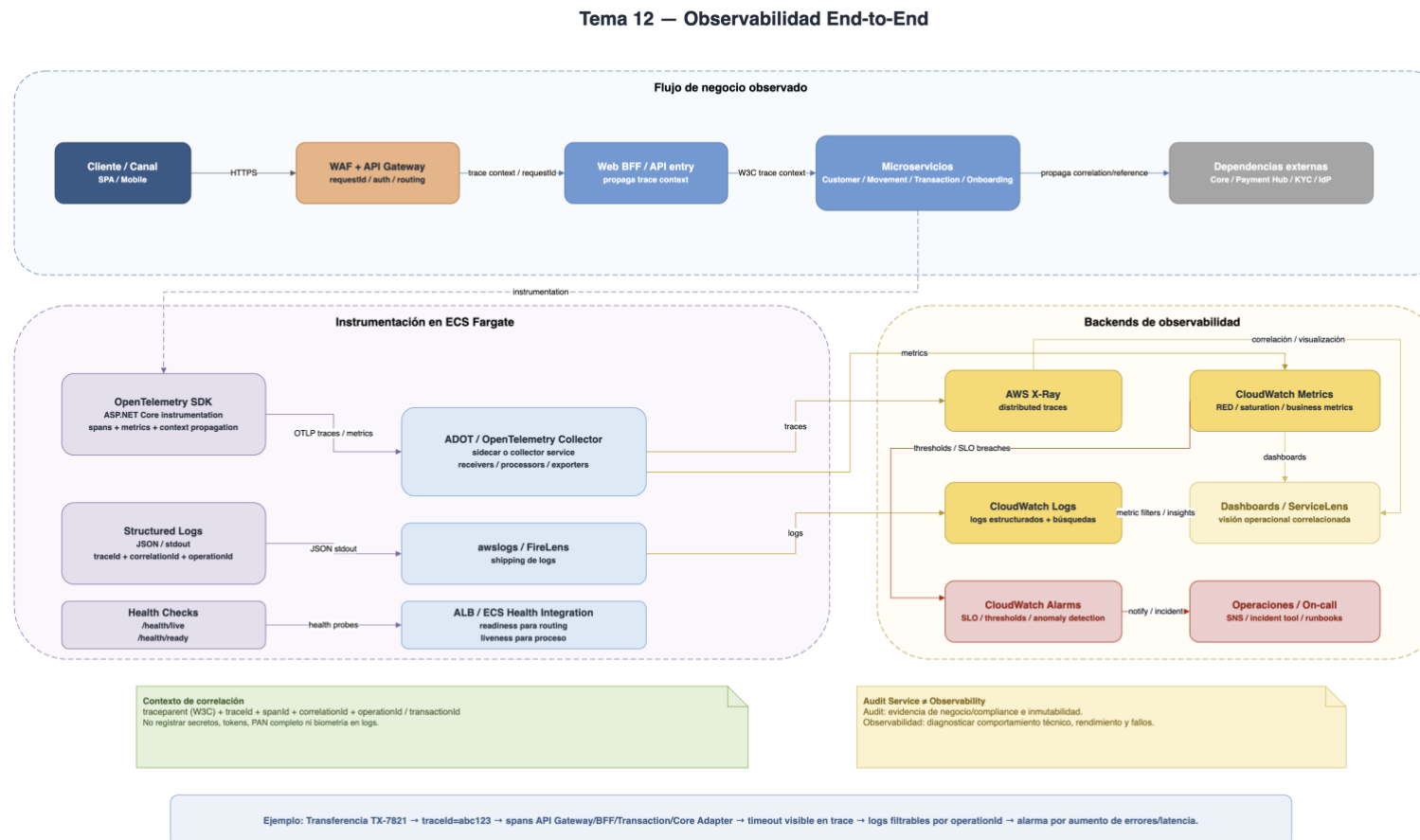


Figura 8. Observabilidad End to End.

Capa	Controles
Identidad	OIDC/OAuth 2.0; Code + PKCE; MFA/step-up; passkeys; IAM least privilege; sin claves estáticas en código.
Sesión web	BFF; cookies Secure/HttpOnly/SameSite; defensa CSRF; tokens fuera de localStorage.
API	API Gateway, rate limiting, validación de contratos, WAF y políticas de autorización por canal.
Red	Cargas en subredes privadas, security groups, endpoints privados cuando aporten valor, conectividad híbrida y cifrado en tránsito.
Datos	TLS, KMS, Secrets Manager, clasificación/minimización, backups cifrados y retención aprobada.
Aplicación	OWASP ASVS/MASVS; SAST, SCA, DAST, scanning de secretos e imágenes.
Detección	GuardDuty, Security Hub, CloudTrail, Config y SIEM corporativo.
Gobierno	Separación de cuentas/ambientes, SCP/guardrails, IaC, revisión de cambios y trazabilidad.

Práctica	Implementación
Logs	JSON estructurado, PII enmascarada, IDs de cliente/transacción/correlación, retención por criticidad.
Métricas	p50/p95/p99, error rate, auth failures, cache hit ratio, saturation, queue age/depth, DLQ, latencia de Core/proveedores.
Tracing	OpenTelemetry/ADOT; trace ID propagado BFF -> API -> servicio -> adapter -> evento.
SLO y alertas	Alertas por impacto a cliente y saturación, no solo CPU; error budgets si la organización los adopta.
CI/CD	Pruebas, SAST/SCA, image scan, policy checks y despliegue rolling/blue-green según criticidad.
Operación	Runbooks, playbooks, pruebas de restauración/failover y revisiones post-incidente con análisis de causa raíz.

Auto-healing resuelve fallos de proceso o capacidad; no resuelve por sí solo una dependencia externa caída, un evento duplicado, una operación en estado desconocido o un error lógico. La resiliencia depende de los patrones de aplicación además de la plataforma.

13. Marco regulatorio ecuatoriano

Esta sección identifica impactos arquitectónicos, no constituye asesoría legal. Para un proyecto real, Cumplimiento, Asesoría Jurídica, Riesgos, Seguridad y el Delegado de Protección de Datos deben validar la interpretación y la documentación entregada al regulador.

Marco	Impacto arquitectónico
LOPD + Reglamento General	Privacidad desde el diseño y por defecto, minimización, seguridad, transparencia, derechos del titular, gestión de encargados y conservación. Los datos biométricos requieren tratamiento reforzado.
SPDP-SPD-2026-0004-R	Regula transferencias/comunicaciones nacionales e internacionales. Debe documentarse el rol de cada tercero y el marco contractual; la ubicación en el extranjero no convierte por sí sola un encargo válido en una transferencia.
SPDP-SPD-2026-0039-R	Norma general para tratamiento de datos biométricos. El onboarding facial requiere finalidad clara, proporcionalidad, evaluación de riesgos/impacto y controles de retención y acceso acordes.

Marco	Impacto arquitectónico
SPDP-SPD-2026-0040-R	Norma técnica de notificación de vulneraciones. El proceso de incident response debe conservar evidencia, clasificar impacto y soportar los flujos de notificación aplicables.
Superintendencia de Bancos - Codificación vigente de riesgo operativo	Servicios provistos por terceros y cloud: evaluación y monitoreo de riesgos, continuidad, niveles de servicio, notificación de procesos críticos y requisitos técnicos/certificaciones aplicables al proveedor.
BCE / Sistema Central de Pagos - SPI y normativa aplicable	El canal digital debe respetar el mecanismo corporativo de participación, referencias, horarios/cortes, conectividad, reconciliación e irrevocabilidad que correspondan.
PCI DSS - condicional	Solo se incorpora al alcance si BP procesa, almacena o transmite datos de tarjeta dentro del flujo definido.
ISO 27001/27017/27018 y 22301	Referencias de control y evidencia del proveedor; no sustituyen la responsabilidad del banco ni los requisitos locales.

Punto de control regulatorio: la Codificación vigente de la Superintendencia de Bancos mantiene exigencias específicas para servicios en la nube, entre ellas ANSI-TIA-942 o superior, TIER III o equivalente y controles/certificaciones de seguridad del proveedor. AWS publica certificaciones y un Compliance Center para Ecuador, pero BP debe verificar el alcance exacto de cada región y servicio, y confirmar con Cumplimiento y Jurídico que la evidencia presentada satisface la normativa aplicable. Esta validación es un prerrequisito para producción.

14. Decisiones arquitectónicas y alternativas

La siguiente matriz resume las decisiones principales. Cada una conserva dos motivos explícitos y el costo o riesgo que introduce, tal como solicita el ejercicio.

Decisión	Elegido	Alternativas	Dos razones	Compromiso / costo
ADR-01 Plataforma cloud	AWS	Azure / on-prem	1) Servicios administrados para HA, seguridad y observabilidad. 2) AWS publica certificaciones y guía de cumplimiento para instituciones financieras en Ecuador.	Dependencia del proveedor; el cumplimiento sigue siendo responsabilidad de BP.
ADR-02 Región	Región por validar; us-east-1 / us-east-2 solo como referencia de diseño	sa-east-1 / mx-central-1 / otras regiones candidatas	1) Permite modelar una solución concreta sin presentar la región como decisión cerrada. 2) La selección final debe basarse en latencia medida, servicios disponibles, costo, continuidad y cumplimiento.	La arquitectura debe revalidarse si la región elegida cambia restricciones, latencia o disponibilidad de servicios.
ADR-03 Runtime	ECS Fargate	EKS / EC2 / Lambda	1) Escalado y reemplazo de tasks sin administrar nodos. 2) Menor complejidad operativa que EKS si no existe requisito Kubernetes.	Menor control de infraestructura; costo por unidad puede ser mayor que EC2 a carga estable.
ADR-04 Web	React + TypeScript + BFF	SPA con tokens / MVC	1) Mantiene una UX SPA sin exponer tokens al navegador. 2) BFF es el patrón de mayor seguridad de RFC 10017 para aplicaciones sensibles.	Añade un componente del lado servidor y un salto de red.
ADR-05 Móvil	Flutter	React Native	1) Experiencia y UI consistentes cross-platform. 2) Buen acceso a SDKs nativos mediante plugins.	React Native puede ser mejor si BP ya estandarizó React/TypeScript.
ADR-06 OAuth	Authorization Code + PKCE + OIDC	Implicit / password grant	1) Alineado con BCP actuales de OAuth. 2) En móvil evita capturar credenciales en la app y reduce exposición de tokens.	Exige un IdP moderno y manejo correcto de redirects, sesiones y recuperación.
ADR-07 Entrada API	Amazon API Gateway	ALB directo / gateway propio	1) Centraliza throttling, routing y políticas de API. 2) Reduce operación frente a un gateway construido por el banco.	Costo por request y límites de servicio; no sustituye el diseño de contratos.

Decisión	Elegido	Alternativas	Dos razones	Compromiso / costo
ADR-08 Legado	ACL + adapters	Servicios acoplados directamente al Core	1) Localiza cambios de protocolos/modelos legacy. 2) Facilita pruebas y reemplazo de proveedores.	Añade una capa y una pequeña latencia adicional.
ADR-09 Async	EventBridge + SQS + DLQ	MSK/Kafka / RabbitMQ / solo sync	1) Desacopla notificación y auditoría derivada. 2) Menor operación que Kafka para un volumen no especificado.	No ofrece por defecto el mismo modelo de log/replay/particiones de Kafka.
ADR-10 Persistencia transaccional	Aurora PostgreSQL propiedad del Transaction Service	DynamoDB / BD compartida	1) Idempotencia, estado y Outbox encajan bien en transacciones relacionales. 2) La propiedad exclusiva evita acoplamiento por tablas.	Más costo que un KV simple; no deben proliferar bases sin necesidad.
ADR-11 Caché	Redis + Cache-Aside	Sin caché / read replica / materialized view	1) Reduce latencia y carga sobre legados. 2) TTL permite limitar obsolescencia.	Puede quedar desactualizado; nunca es autoridad para saldo o ejecución monetaria.
ADR-12 Entrega confiable	Idempotencia + Outbox	Retry ciego / dual write DB+broker	1) Evita efectos duplicados. 2) Elimina el riesgo del dual write sin 2PC distribuido.	Requiere worker, limpieza de Outbox y consumidores idempotentes.
ADR-13 Auditoría	Audit DB + S3 Object Lock	Solo CloudWatch/CloudTrail	1) Se necesita semántica bancaria, no solo infraestructura. 2) Archivo inmutable aporta evidencia y retención.	Costo de almacenamiento y necesidad de políticas legales de acceso/retención.
ADR-14 DR	Warm standby como hipótesis de diseño; validar con BIA	Backup & restore / pilot light / active-active	1) Ofrece mejor tiempo de recuperación que backup & restore. 2) Evita la complejidad y costo de active-active cuando no existe un requisito que lo justifique.	Mantiene capacidad ociosa y exige pruebas periódicas; el BIA puede llevar a otra estrategia.
ADR-15 Conectividad	DX/Hosted Connection redundante + VPN	Internet-only / un solo circuito	1) Reduce dependencia de Internet para integración con Core. 2) Diversidad de caminos reduce SPOF.	Costo de carriers/partners y riesgo de falsa diversidad física.
ADR-16 Notificaciones	E-mail + SMS independientes; push opcional	Proveedor único síncrono	1) Cumple el requisito de al menos dos mecanismos. 2) Adaptadores permiten cambiar proveedor sin modificar la transacción.	La notificación es eventual: puede llegar después de confirmarse la operación.
ADR-17 Landing Zone y cuentas	AWS Organizations + Control Tower / landing zone corporativa	Cuenta única / landing zone ad hoc	1) Aísla producción, seguridad y evidencia, reduciendo radio de impacto. 2) Facilita segregación de funciones, guardrails y administración centralizada.	Más cuentas, políticas y procesos de gobierno que deben operar con disciplina.
ADR-18 IaC y entrega	CloudFormation/CDK + CI/CD como opción base	Consola manual / Terraform u otra IaC corporativa	1) Hace reproducibles los despliegues y reduce deriva de configuración. 2) Permite reconstrucción y DR con evidencia de cambios y pruebas automatizadas.	Requiere ingeniería de plataforma, pipeline seguro y gobierno del código de infraestructura.

15. Costos, operación y riesgos abiertos

15.1 Criterios de costo

Decisión	Racional
Fargate antes que EKS	Evita administrar nodos y reduce la carga operativa inicial.
EventBridge + SQS antes que MSK	Pago por uso y menor complejidad para eventos de negocio convencionales.
Warm standby antes que active-active	Reduce duplicación permanente de capacidad y complejidad de consistencia.
S3 + CloudFront para SPA	El contenido estático no consume capacidad de aplicación.
Redis solo si las métricas lo justifican	El hit ratio y la reducción de carga sobre el legado deben demostrar su valor.
Retención por nivel	Logs calientes por el tiempo operativo necesario; archivo de evidencia según la política de auditoría.

Decisión	Racional
Savings Plans después de medir	No comprometer capacidad hasta disponer de un línea base de consumo estable.
FinOps desde el inicio	Etiquetado de costos, AWS Budgets, Cost Explorer y Cost Anomaly Detection, con owner/cost center por servicio, para detectar desviaciones y asignar responsabilidad desde el inicio.
Service Quotas como control de confiabilidad	Las cuotas se revisan y monitorean antes de pruebas de carga y crecimiento para evitar que una arquitectura escalable falle por límites de cuenta o servicio.

15.2 Riesgos y decisiones que siguen abiertas

Riesgo / pregunta	Acción previa a producción
Latencia Ecuador -> AWS -> Core	PoC con carriers del banco; comparar regiones y medir p50/p95/p99 con tráfico representativo.
Aprobación regulatoria de cloud	Validar la Codificación vigente de la SB, evidencia TIER III/equivalente, certificaciones, contratos, auditoría, tratamiento de datos y estrategia de salida.
Capacidades reales del IdP	Confirmar OIDC, PKCE, MFA, step-up, passkeys, refresh rotation y provisioning APIs.
Mecanismo interbancario de BP	Revisar hub actual, mecanismo BCE aplicable, formatos, cortes, contingencia y reconciliación.
BIA / RTO / RPO	Aprobar objetivos por capability antes de cerrar replicación y capacidad de la segunda región.
Modelo de datos personales	DPO/Legal deben definir roles de responsable/encargado, contratos, finalidades, retención y tratamiento transfronterizo.
Biometría	DPIA/evaluación de impacto, proveedor, umbrales, revisión humana, alternativa y política de eliminación.
Madurez DevSecOps/SRE	Si es insuficiente, reducir las unidades desplegadas iniciales y mantener límites lógicos para evolucionar gradualmente.

17. Referencias

Fuente	Uso en la propuesta
Cervantes, H.; Kazman, R.	Designing Software Architectures: A Practical Approach. Addison-Wesley. Referencia para drivers, ADD, tácticas y decisiones de diseño.
Bass, L.; Clements, P.; Kazman, R.	Software Architecture in Practice, 3rd ed. Referencia para atributos de calidad, tácticas, vistas y evaluación arquitectónica.
IETF RFC 10017 (2026)	OAuth 2.0 for Browser-Based Applications. BCP 212.
IETF RFC 9700	Best Current Practice for OAuth 2.0 Security.
IETF RFC 8252	OAuth 2.0 for Native Apps.
Registro Oficial del Ecuador	Ley Orgánica de Protección de Datos Personales, Quinto Suplemento No. 459, 26-may-2021; Reglamento General, Decreto 904.
Superintendencia de Protección de Datos Personales	Resoluciones SPDP-SPD-2026-0004-R, SPDP-SPD-2026-0039-R y SPDP-SPD-2026-0040-R.
Superintendencia de Bancos	Codificación de las Normas de la Superintendencia de Bancos, Libro I, Título IX, Capítulo V - Norma de control para la gestión del riesgo operativo; actualización mediante SB-2023-01901 y reformas posteriores, incluida SB-2024-02855.
Banco Central del Ecuador	Sistema de Pagos Interbancarios (SPI) y normativa del Sistema Central de Pagos.

Fuente	Uso en la propuesta
AWS	Compliance Center - Ecuador; ISO and CSA STAR Certified; AWS Shared Responsibility Model y documentación de regiones/servicios.
AWS Well-Architected Framework	Referencia para revisar excelencia operativa, seguridad, confiabilidad, eficiencia del rendimiento, optimización de costos y sostenibilidad; además de prácticas de gobierno, automatización, recuperación y servicios administrados.

Conclusión: La propuesta cubre los entregables y criterios del ejercicio y puede defenderse ante un equipo de negocio, tecnología, riesgos y seguridad. Antes de llevarla a producción deben cerrarse con evidencia del banco cuatro decisiones: región AWS, objetivos BIA/RTO/RPO, capacidades reales de los sistemas corporativos especialmente IdP, hub de pagos y aprobación regulatoria/contractual del uso de cloud y biometría.